

Clase 285 — Auditoría de seguridad

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide y SOC 2 (AICPA)

 Duración estimada: **100 min** · Nivel: **Intermedio**

Objetivo

Aprender qué es una auditoría de seguridad, cómo se planifica y ejecuta, y cómo se sobrevive a ella desde el lado auditado. Al terminar sabrás distinguir auditoría interna de externa, recopilar y presentar evidencia, entender los informes SOC 1/SOC 2/SOC 3, gestionar hallazgos y no conformidades, y usar la auditoría como herramienta de mejora, no como examen temido.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Diferenciar** auditoría interna, externa, de primera/segunda/tercera parte.
2. **Planificar** una auditoría: alcance, criterios, plan y muestreo.
3. **Recopilar** y organizar evidencia de auditoría trazable.
4. **Interpretar** informes SOC 1/SOC 2 (Type I vs Type II).
5. **Gestionar** hallazgos, no conformidades y planes de acción correctiva.

Temas

#	Tema	Por qué importa
1	Tipos de auditoría y de auditor	Independencia y objetividad
2	Proceso de auditoría	Planificación, ejecución, informe, seguimiento
3	Criterios y evidencia	Contra qué se audita y con qué se prueba
4	Muestreo y pruebas	Cómo se verifica sin revisar el 100%
5	Informes SOC 1/2/3 y Type I/II	El estándar de aseguramiento de proveedores
6	Hallazgos y CAPA	Del hallazgo a la corrección
7	Auditoría continua y automatizada	Evidencia en tiempo real

Definiciones y características

- **Auditoría de seguridad:** evaluación sistemática e independiente de controles frente a un criterio.
Clave: independencia y objetividad.
- **Auditor de primera/segunda/tercera parte:** interno, del cliente, o externo independiente. *Clave:* la certificación exige tercera parte.
- **Criterio de auditoría:** el estándar contra el que se compara (ISO 27001, PCI-DSS, política interna).
Clave: sin criterio no hay auditoría.

- **Evidencia:** registros, entrevistas, observaciones y reejecuciones que sustentan una conclusión. *Clave:* debe ser trazable y suficiente.
- **SOC 2:** informe de aseguramiento sobre los Trust Services Criteria (seguridad, disponibilidad, confidencialidad, etc.). *Clave:* Type I evalúa el diseño; Type II, la eficacia operativa en un periodo.
- **Hallazgo / no conformidad:** incumplimiento detectado; mayor o menor. *Clave:* genera acción correctiva.
- **CAPA:** acción correctiva y preventiva. *Clave:* corrige la causa raíz, no solo el síntoma.

Herramientas y preparación

- Hoja de cálculo para el plan de auditoría, la matriz de evidencia y el registro de hallazgos.
- Referencia: *ISO 19011* (directrices para auditar sistemas de gestión) y los *Trust Services Criteria* de AICPA (SOC 2).
- Para evidencia técnica: capturas de configuración, logs, exportaciones de un IAM/SIEM (reutiliza lo aprendido en partes previas).
- Opcional: herramientas GRC de recolección continua de evidencia (Vanta, Drata) a nivel conceptual.

Laboratorio guiado (ejercicio aplicado)

Vas a preparar y "ejecutar" una auditoría interna de control de acceso en "Ferretería del Sur S.A.".

1. **Alcance y criterio:** define el alcance ("gestión de accesos a la plataforma de e-commerce") y el criterio (la política de la clase 282 y el control ISO 27001 A.5.15/A.8.2).
2. **Plan de auditoría:** redacta un plan con objetivos, criterio, áreas, entrevistados, fechas y método (revisión documental + muestreo técnico).
3. **Diseño de pruebas:** para 4 controles (MFA obligatorio, revocación de accesos al cese, principio de mínimo privilegio, revisión trimestral de permisos), define qué evidencia solicitarías y cómo la verificarías.
4. **Muestreo:** de una lista ficticia de 50 usuarios, define una muestra de 10 y comprueba (con datos de ejemplo) si tienen MFA y si los ex-empleados están deshabilitados.
5. **Registro de hallazgos:** documenta al menos 2 hallazgos (p. ej. "3 de 10 cuentas sin MFA"; "1 ex-empleado con acceso activo"), clasifícalos en mayor/menor y anota la evidencia.
6. **CAPA:** para cada hallazgo redacta la acción correctiva, la causa raíz y la fecha de cierre.
7. **Informe:** escribe un resumen ejecutivo de media página con conclusión (conforme con salvedades) y las recomendaciones priorizadas.
8. **SOC 2:** explica en 3 líneas si pedirías a tu proveedor cloud un SOC 2 Type I o Type II y por qué.

Ejercicios

1. Diferencia auditoría de primera, segunda y tercera parte con un ejemplo.
2. ¿Por qué el auditor no puede auditar su propio trabajo? Explica el principio de independencia.
3. Convierte un control ("los accesos se revisan trimestralmente") en una prueba de auditoría con evidencia concreta.
4. Explica la diferencia entre SOC 2 Type I y Type II.
5. Clasifica en mayor/menor: falta total de MFA en administradores; una excepción documentada y aprobada.
6. Redacta una CAPA para el hallazgo "logs del SIEM se retienen 7 días en lugar de 90".

Reto verificable

Entrega un **paquete de auditoría interna** con: plan de auditoría, diseño de pruebas para 4 controles, muestreo ejecutado con hallazgos clasificados, CAPA por hallazgo y un informe ejecutivo con conclusión.

Criterio de aceptación: cada hallazgo cita evidencia y criterio incumplido, cada CAPA identifica causa raíz y fecha de cierre, y el informe distingue hallazgos mayores de menores con recomendaciones priorizadas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Auditar sin criterio definido	Conclusiones subjetivas; fija el estándar antes de empezar
Evidencia anecdótica ("me dijeron que...")	No es trazable; exige registros, configuraciones o logs
Auditor sin independencia	Conflicto de interés; separa quien opera de quien audita
Hallazgos sin causa raíz	Se repiten; en la CAPA analiza el porqué, no solo el qué
Confundir SOC 2 Type I con Type II	Type I es diseño puntual; Type II prueba eficacia en el tiempo

Preguntas frecuentes

 **¿La auditoría es lo mismo que un pentest?** No. El pentest prueba explotabilidad técnica; la auditoría evalúa si los controles existen, están diseñados y operan según un criterio. Se complementan.

 **¿SOC 2 lo emite cualquiera?** No; lo emite un auditor CPA independiente conforme a los estándares de la AICPA. Por eso da aseguramiento a los clientes del proveedor.

 **¿Una no conformidad menor bloquea la certificación?** Normalmente no si se aborda con una CAPA; una mayor sí suele bloquearla hasta corregirse. Depende del esquema.

 **¿Qué es la auditoría continua?** El uso de herramientas que recolectan evidencia automáticamente (configuraciones, logs, controles) de forma permanente, en lugar de una foto anual.

Referencias

- ISO 19011:2018 — Directrices para la auditoría de sistemas de gestión. <https://www.iso.org/standard/70017.html>
- AICPA — SOC 2 y Trust Services Criteria. <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>
- ISACA — IT Audit Framework (ITAF). <https://www.isaca.org/resources/itaf>
- (ISC)² CISSP Official Study Guide, dominio 6 (Security Assessment and Testing).
- NIST SP 800-53A — Assessing Security Controls. <https://csrc.nist.gov/pubs/sp/800/53/a/r5/final>

Siguiente clase

Clase 286 - Concienciación y cultura de seguridad